Unified Security Audit | Phase 2

Consolidated NIST, CIS, and NIS2 risk report

This unified report merges the original topology-led audit with the teammate's configuration compliance audit. The conclusion is stricter than the first report because the second review found evidence that several declared controls may not actually be active.

UNIFIED POSTURE

High

Risk increased. The combined evidence moves the project from moderate residual risk to high risk.

COMPLIANCE VIEW

30%

Approximate compliance. Teammate review estimates 25-30% against NIST SP 800-53 Rev. 5.

REASON

26

Additional findings. Four are critical and several show documentation/configuration drift.

PROJECT

Packet Tracer network

DATE

April 23, 2026

CLASSIFICATION

Confidential

AUDIENCE

Leadership and technical team

ARCHITECTURE STRENGTH

Good segmentation design.
The topology still shows useful separation: user VLANs, DMZ, internal servers, storage, and network management.

COMPLIANCE GAP

Declared controls are not always active.
Examples include CoPP not attached and the VLAN 40 ACL not applied.

BUSINESS RISK

Identity and routing errors create exposure.
Weak credentials, VTY gaps, and incorrect PC gateways undermine the segmentation story.

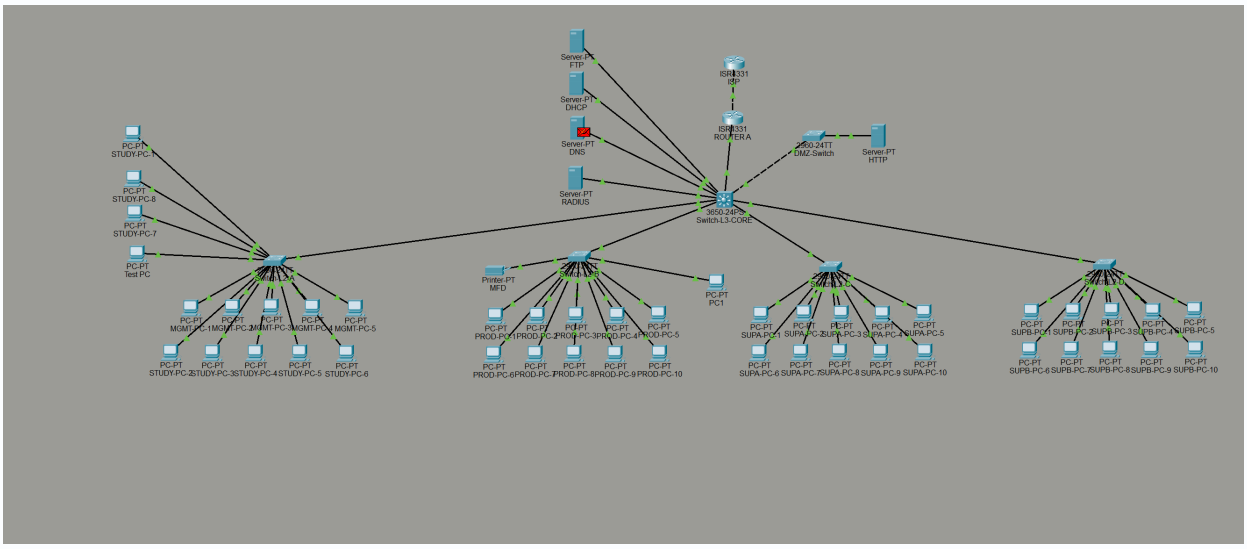
Unified Conclusion

The first report correctly recognized a good learning-level security architecture. The second report adds a configuration reality check and shows that multiple controls may be missing, misapplied, or bypassed. The defensible final position is: **good topology concept, insufficient implementation assurance, high risk until the critical and high findings are corrected.**

Top Management Priorities

1	**Fix endpoint default gateways.** VLAN 20, 30, and 40 PCs reportedly use 192.168.10.1 instead of their own VLAN gateways, bypassing the intended ACLs.	Critical
2	**Secure network-device administration.** L2 switches may have VTY login without local authentication, while trivial enable passwords and weak secrets are documented.	Critical
3	**Activate declared controls.** Attach CoPP to the control plane and apply the missing VLAN 40 ACL before claiming those controls exist.	Critical
4	**Tighten management and printer zones.** VLAN 99 and VLAN 50 need explicit ACLs and a deny-by-default approach.	High
5	**Resolve routing, DNS, syslog, and monitoring gaps.** Dual default routes, broad DNS rules, wrong syslog targets, and missing ACL logs weaken operations and auditability.	Medium

Topology Anchor



ZONE	DESIGN INTENT	COMBINED AUDIT CONCERN	STATUS
VLAN 10	Management/Study gateway 192.168.10.1	Incorrect gateways may route other departments through this SVI.	Critical
VLAN 20/30/40	Production and Support segmentation	Gateway errors and missing VLAN 40 ACL may bypass the segmentation.	Critical
VLAN 50	Printer/MFD isolation	No confirmed ACL; printer subnet differs from earlier report assumptions.	High
VLAN 60	DMZ web isolation	DMZ ACL ordering may permit established flows before intended denies.	Review
VLAN 70	DNS, DHCP, RADIUS services	Broad DNS, weak RADIUS key, and service exposure need tightening.	High
VLAN 99	Network-device management	No ACL and possible IP conflict on L2-C/L2-D management interfaces.	High

Critical And High Findings

PRIORITY	UNIFIED FINDING	EVIDENCE BASIS	FRAMEWORK MAPPING	RISK
1	Segmentation bypass through wrong PC gateways	VLAN 20/30/40 PCs reportedly use 192.168.10.1 instead of .33/.65/.97.	NIST AC-4, SC-7, CM-6	Critical
2	Network-device access can be compromised	No VTY authentication on L2 switches, trivial enable password 0000, weak admin secrets.	NIST IA-2, IA-5, AC-17; CIS IOS	Critical
3	Declared controls not implemented	CoPP policy defined but not attached; VLAN 40 ACL defined but not applied.	NIST CM-6, CM-9, CA-7	Critical
4	Insecure management and device services	SSH v1 on Router A, possible missing L3-core RSA keys, console login gaps.	NIST IA-2, SC-8, SC-23	High
5	Management and printer VLANs lack protection	No ACL on VLAN 99 and VLAN 50.	NIST AC-3, SC-7, MA-4	High
6	ACL logic and scope are too permissive	DMZ established rule order, UDP any/any, broad DNS, catch-all permits.	NIST AC-4, SC-7, CM-7	High
7	Service credentials and FTP permissions are weak	RADIUS cisco123; FTP admin/admin, cisco/cisco, securityasiye/0000 with RWDNL.	NIST IA-5, IA-3; MITRE T1078	High
8	Availability and routing confidence are weak	Single core, single router, conflicting default routes, partial STP priority.	NIST CP-10, SC-5, SC-7	Medium/High

Positive Controls To Keep

CONTROL	WHY IT HELPS	STATUS
VLAN-based security zones	Good architectural base for least privilege and DMZ separation.	Keep
Perimeter ACL concept	Inbound internet traffic is intended to be restricted to the DMZ service.	Tighten
Port security on L2-A/B/C	Limits unauthorized endpoint attachment on several access switches.	Keep
Syslog and NTP concept	Supports auditability and incident investigation if corrected and monitored.	Improve

Control Family Status

FAMILY	UNIFIED ASSESSMENT	REASON	STATUS
AC - Access Control	Non-compliant	Missing ACLs, broad permits, VLAN bypass, VTY gaps.	Critical
IA - Identification and Authentication	Non-compliant	Weak passwords, weak RADIUS key, SSH/VTY issues.	Critical
CM - Configuration Management	Non-compliant	Declared controls differ from actual configs; orphan/unused controls exist.	High
SC - System and Communications Protection	Partial	Segmentation exists, but ACL and SSH weaknesses remain.	High
AU - Audit and Accountability	Partial	Syslog exists, but deny logging and correct destinations are incomplete.	Medium
CP - Contingency Planning	Partial	No true high availability; core and edge remain single dependencies.	Medium
IR - Incident Response	Not defined	No response workflow, retention decision, or escalation process shown.	Gap

NIS2 defensibility depends on proving that controls are implemented, monitored, and maintained. The combined report shows that the design intent is strong, but the implementation evidence is not strong enough to defend as compliant.

Unified Grade

ORIGINAL REPORT

67/100

Moderate residual risk based on topology, architecture, and known lab limitations.

UNIFIED REPORT

30/100

High risk after adding configuration drift, unauthenticated access, VLAN bypass, and critical implementation gaps.

Remediation Plan

PHASE	ACTIONS	EXPECTED RESULT
Immediate	Fix VTY authentication, replace enable password 0000, correct PC gateways, apply VLAN 40 ACL.	Stops the most serious access and segmentation failures.
Short term	Force SSHv2, generate RSA keys, attach CoPP, add ACLs to VLAN 50 and VLAN 99, fix default routes.	Brings declared controls closer to actual running configuration.
Medium term	Rewrite broad ACLs, narrow DNS and NAT rules, fix syslog/NTP/DNS client settings, add deny logging.	Improves least privilege, monitoring, and operational evidence.
Long term	Add redundant core/edge design, formal incident response, configuration baselines, and recurring compliance checks.	Makes the design defensible for NIS2/NIST governance.

Final Unified Conclusion

The unified audit should be presented honestly: the network architecture is a good starting point, but the implementation has enough critical gaps that it should be graded high risk and non-compliant until remediated. The strongest defense is to show the topology, acknowledge the evidence limitations, and then explain exactly which controls must be fixed first.